

Bonus 1: Isolamento minaccia tramite analisi HTTP e DNS

Executive Summary

Questo report **analizza le evidenze nei log** relativi allo sfruttamento delle vulnerabilità nei protocolli **DNS e HTTP** attraverso **Kibana**.

Domanda 1

Qual è l'indirizzo IP sorgente?

209.165.200.227

Domanda 2

Qual è l'indirizzo IP destinazione?

209.165.200.235

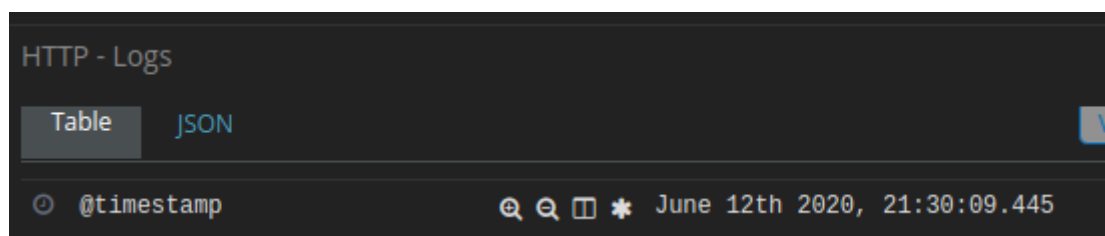
Domanda 3

Qual è il numero di porta destinazione?

80

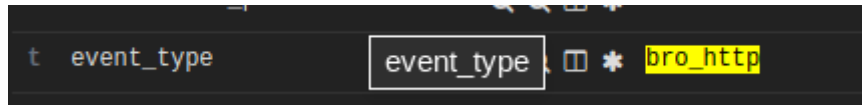
Domanda 4

Qual è il timestamp del primo risultato?



Domanda 5

Qual è il tipo di evento?



Domanda 6

Cosa è incluso nel campo message?

Si vedono i parametri della REQUEST (HTTP GET) e alcuni dati sulla risposta (Response_body_len, status_code ecc...)

```
{ "ts": "2020-06-12T21:30:09.445030Z", "uid": "CuKeR52aPjRN7PfQDd", "id.orig_h": "209.165.200.227", "id.orig_p": 56194, "id.resp_h": "209.165.200.235", "id.resp_p": 80, "trans_depth": 1, "method": "GET", "host": "209.165.200.235", "uri": "/mutillidae/index.php?page=user-info.php&username='+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+--+&password=&user-info-php-submit-button=View+Account+Details'", "referrer": "http://209.165.200.235/mutillidae/index.php?page=user-info.php", "version": "1.1", "user_agent": "Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0", "request_body_len": 0, "response_body_len": 23665, "status_code": 200, "status_msg": "OK", "tags": ["HTTP::URI_Sqli"], "resp_fuids": ["FEvWs63HqvCqth3LH1"], "resp_mime_types": ["text/html"] }
```

Domanda 7

Questi sono dettagli sulla richiesta HTTP GET fatta dal client al server. Concentrati specialmente sul campo uri nel testo del messaggio. Qual è il significato di queste informazioni?

Troviamo UID, Host e altre informazioni generali sul tipo della richiesta.

Concentrandosi sul campo URL troviamo una SQLI, precisamente una "Injection Union Select". Si vedono parametri request di HTTP GET e si può apprezzare nel campo "uri" i vari dati cercati nel database, riguardo alle carte di credito degli utenti.

Campi richiesti:

- **ccid** : ID della carta
- **ccnum**: Numero della carta
- **ccv**: Codice di verifica della carta
- **expiration** : Data di scadenza

Tabella:

- credit_cards

Sede di injection:

- username input field

Altri dettagli:

- **La colonna "Null":** Nel log si vede null+from. Negli attacchi di tipo UNION, il numero di colonne nella SELECT iniettata deve corrispondere esattamente al numero di colonne della SELECT originale. L'attaccante ha usato null come "riempitivo" (padding) per soddisfare questo requisito strutturale.
- **Sintassi dei commenti:** Il --+ alla fine del payload è un commento SQL. Questo istruisce il database a ignorare tutto il resto della query "legittima" originale, prevenendo errori di sintassi che bloccherebbero l'esecuzione dell'exploit.
- **L'applicazione target:** L'URI mostra /mutillidae/. OWASP Mutillidae II è una celebre applicazione web deliberatamente vulnerabile. Riconoscere questi "nomi da laboratorio" ti aiuta a identificare rapidamente se un avviso indica un attacco reale o un collega/studente che si sta esercitando.
- **Tagging dell'IDS:** In fondo al log, il campo "tags":["HTTP::URI_SQLI"] mostra che il Sistema di Rilevamento delle Intrusioni (IDS) ha categorizzato automaticamente questo evento con successo.

Domanda 9

Cosa vedi più avanti nella trascrizione riguardo ai nomi utente? Fornisci alcuni esempi di nome utente, password e firma che sono stati esfiltrati.

Analizzando e cercando nel File pcap trovo le risposte date all'utente grazie alla SQLI, in chiaro infatti vengono visualizzati Username, Password e signature.

```

DST:
DST: 24
DST: <b>Username=</b>4444111122223333<br>
DST:
DST: 17
DST: <b>Password=</b>745<br>
DST:
DST: 22
DST: <b>Signature=</b>2012-03-01<br><p>
DST:
DST: 24
DST: <b>Username=</b>7746536337776330<br>
DST:
DST: 17
DST: <b>Password=</b>722<br>
DST:
DST: 22
DST: <b>Signature=</b>2015-04-01<br><p>
DST:

```

Domanda 10

Registra gli indirizzi IP del client e del server DNS.

DNS - Client		DNS - Server	
Client	Count	Server	Count
192.168.0.11	4	209.165.200.235	4

Domanda 11

I sottodomini delle query DNS erano sottodomini? Se no, qual è il testo?

```

analyst@Sec0nion:~/Downloads$ xxd -r -p "DNS - Queries.csv" > secret.txt
analyst@Sec0nion:~/Downloads$ cat secret.txt
CONFIDENTIAL DOCUMENT
DO NOT SHARE
This document contains information about the last security breach.
analyst@Sec0nion:~/Downloads$ █

```

Domanda 12

Cosa implica questo risultato riguardo a queste particolari richieste DNS? Qual è il significato più ampio?

Implica che il protocollo DNS è stato sfruttato per cercare un “data exfiltration”, usando la tecnico del DNS Tunneling. Il significato più ampio, è il tentativo da parte dell'attaccante, di segmentare un file riservato, convertendolo in esadecimale e inserendolo nelle richieste DNS.

Domanda 13

Cosa potrebbe aver creato queste query DNS codificate e perché è stato scelto il DNS come mezzo per esfiltrare dati?

DNS Tunneling e DNS Data Exfiltration.

Vantaggi di questo tipo di attacco:

- **Superamento dei Firewall:** Molti firewall lasciano passare il traffico sulla porta UDP 53 (DNS) senza restrizioni, considerandolo traffico di servizio essenziale.
- **Invisibilità:** Se l'attaccante è lento (poche query al minuto), l'attacco può mimetizzarsi nel normale traffico web.